XOR SECURE CLOUD

Kế hoạch đối soát thiết kế và tồn tại từ hồ sơ tham khảo

Bổ sung cho sổ tay và checklist kỹ thuật

Nền tảng XOR STACK CLOUD dựa trên OpenStack

DC tại Trung tâm Hạ tầng IDC Cầu Giấy
DR tại Trung tâm Hạ tầng IDC Nam Thăng Long

Bản dự thảo 2.2 ngày 17 tháng 10 năm 2026

Khối Hạ tầng & Vận hành sử dụng tài liệu này để đối soát thiết kế trong bản 0.9.4 với nền tảng đang vận hành tại DC Cầu Giấy và DR Nam Thăng Long. Đầu ra cần có là danh mục tài sản được xác nhận, các thay đổi đã nghiệm thu và bằng chứng gắn với từng kiểm soát.

1 Dữ liệu kế thừa và cách xác nhận

Nguồn tham khảo: XOR_SECURE_CLOUD_Ho_so_Cap_do_4_v0.9.4.docx, ngày lập 06/10/2026; Phần II–III, Phụ lục D–G. Số liệu BOM/VLAN là thiết kế ghi trong nguồn, chưa có biên bản kiểm kê hoặc nghiệm thu đi kèm. Không tự phân bổ BOM này cho DC hoặc nhân đôi thành cấu hình DR.

Thông tin	Cách dùng khi rà soát
Tổ chức và phạm vi	Dùng tên Công ty Cổ phần XOR CLOUD; Khối Hạ tầng & Vận hành; toàn bộ XOR STACK CLOUD và quản trị chung. Hai IDC theo xác nhận của chủ quản cung cấp hồ sơ.
129 mục cũ	Giữ đủ mã, nội dung, trạng thái và tồn tại trong workbook 04_Doi_soat_129_hang_muc_v094.xlsx. Cột kết quả hiện tại tách riêng và bắt đầu Chưa xác minh.
119 dòng TC và 18 dòng CL	Tiếp tục dùng workbook 02 để kiểm tra yêu cầu đã diễn giải. Số dòng nội bộ không phải số điều khoản hoặc chứng nhận; không cộng 129 với 119 thành số kiểm soát đã đáp ứng.
Dữ liệu thiếu	Điền kết quả thật, người kiểm tra, ngày và EV. Mọi khác biệt với nguồn phải có kết luận giữ, sửa, thay thế hoặc không áp dụng có căn cứ.

Thống kê trong bản nguồn: 97 Chưa đánh giá; 21 Đang thực hiện; 6 Không đạt; 4 Cần xác minh; 1 Đạt. Đây là trạng thái lịch sử của tài liệu tham khảo, không phải kết quả đánh giá hiện tại.

2 Đối soát thiết bị và năng lực

Nguồn: Phần II mục 4, trang 12–13 của bản 0.9.4. Kỹ thuật bổ sung serial, site/rack/U, đường điện A/B, NIC–switch, firmware, hạn hỗ trợ và mã EV cho từng thiết bị.

Nhóm	SL và model nguồn	Quy hoạch nguồn	Việc cần chốt
Controller	03 Dell R630	128 GB RAM/node; 2 × 480 GB OS và 2 × 800 GB/node; máy 1–2 kiêm SEED.	Chốt vai trò ổ 800 GB, NIC 10/25 Gb, placement và inventory.
Compute	03 Dell R630	512 GB RAM/node; 2 × 480 GB OS/node; máy 4–6.	Chốt gateway/agent đồng vị trí, uplink và năng lực khi mất một host.
Ceph SSD	03 Dell R630	128 GB RAM/node; 10 ổ 1,92 TB phân bố 4/3/3; 19,2 TB raw.	Chốt CRUSH, replica, dung lượng sử dụng và thử recovery.
SAN	01 chưa rõ model	24 ổ 600 GB SAS; 14,4 TB raw; backend riêng.	Chốt giao thức, RAID, controller, fabric và multipath.
Mạng lõi	02 Nexus N9K-C93180YC-EX	Hai nhánh mạng A/B theo quy hoạch.	Port map, peer/keepalive, MTU, cấu hình và failover.
Tường lửa	02 FortiGate 500E	NGFW/IPS/VPN và HA theo thiết kế.	Xác nhận license/support, state sync và phép thử HA.
Mạng SAN và OOB	01 switch SAN; 01 Access	Chưa có model và phương án dự phòng xác nhận.	Đánh giá điểm lỗi đơn, phương án xử lý và kiểm thử.

Tổng RAM theo vai trò: 3 × 128 + 3 × 512 + 3 × 128 = 2.304 GB. Đây là tổng theo thiết kế, không phải RAM bán được. Không dùng số 5.120 GB của bảng định giá cũ thay cho cụm này.

19,2 TB Ceph và 14,4 TB SAN đều là dung lượng raw. Cần tính dung lượng sử dụng riêng theo replica/RAID, dự phòng, mức đầy và khả năng phục hồi. Nguồn chưa có CPU, tải thực, usable/IOPS hoặc kết quả N+1 đủ để cam kết SLA.

3 Đối soát phân vùng mạng

Nguồn: Phần II mục 5, trang 14–15. Bảng sau là quy hoạch logic tham khảo. Giữ sơ đồ kiến trúc mục tiêu của bộ hồ sơ và bổ sung bản vẽ triển khai tại từng site sau khi phê duyệt.

VLAN	Vai trò trong nguồn	Điểm kiểm tra
10	Internal service	Control/service nội bộ; chỉ luồng đã duyệt sang API private.
20	Tenant overlay	Transport tenant; không cấp quyền tới underlay/control/OOB.
30	Ceph client	Client I/O; tên “public” của Ceph không có nghĩa Internet công khai.
31	Ceph cluster	Replication, recovery và heartbeat; cô lập tenant.
40	Security và quản trị	Tách quyền PAM, SIEM, backup và kho log; cần chốt cách phân tách nội vùng.
70	OpenStack API private	Broker/gateway và quản trị được duyệt; TLS, audit và giới hạn quyền.
99	OOB BMC iDRAC	Quản trị ngoài băng; không mở trực tiếp cho tenant/Internet.
100	Portal DMZ	Web/ingress; đường portal tới API thông qua broker theo thiết kế.
Chưa chốt	Provider và SAN	Chốt VLAN/VRF, external gateway, SAN zoning hoặc multipath phù hợp.

Nguồn ghi VLAN 30/40 trong bảng cũ từng có ý nghĩa khác. Không áp cấu hình theo số VLAN khi chưa xác minh ngữ nghĩa. Lập bảng chuyển đổi gồm VLAN/VRF cũ, VLAN/VRF mới, CIDR, gateway, owner, chính sách, ảnh hưởng, kế hoạch chuyển và rollback.

Với mỗi luồng: ghi nguồn, đích, hướng, cổng/giao thức, mục đích, điểm kiểm soát, rule ID và phép thử cho phép/từ chối. WAF chỉ áp dụng giao thức web phù hợp; không bắt mọi lưu lượng VM đi qua WAF. OOB, control, storage và tenant phải được kiểm tra cô lập theo thiết kế đã duyệt.

4 Các mục cần kiểm tra trước

Các mục dưới đây được chọn từ trạng thái Không đạt và Đạt trong bản nguồn. Ưu tiên xác minh phạm vi và phiên bản trước khi quyết định khắc phục; chưa có kết luận chúng còn tồn tại trong production hiện tại.

Mã nguồn	Ghi nhận cũ	Công việc kiểm tra	Đầu mối đề xuất
C4-GOV-10	Nguồn ghi bundle 07 node, LVM/no-Ceph khác thiết kế 09 server.	Đối soát Kolla inventory, CMDB và cấu hình thực tế; phân biệt lab, staging, production.	Platform / PMO
C4-SW-02	Nguồn ghi registry insecure và CVE Critical còn bản vá.	Kiểm tra bản dựng hiện hành, TLS/trust, digest; đối chiếu báo cáo quét và kết quả xử lý.	Platform / SecOps
C4-IAM-06	Nguồn ghi 6 SSH host private key trong image.	Xác minh image/digest; loại khóa dùng chung nếu còn, xoay khóa liên quan, lưu kết quả quét lại.	DevSecOps / IAM
C4-NET-07	Nguồn chưa chứng minh hai tuyến độc lập và failover.	Thu hợp đồng/tuyến vật lý, cấu hình routing và biên bản thử mất tuyến, mất thiết bị.	NetOps / IDC
C4-CLD-16	Nguồn còn IP và tên miền ví dụ.	Kiểm tra cấu hình production, DNS, chứng thư và endpoint; ghi nhận thay thế theo change.	Platform
C4-DC-18	Nguồn cũ ghi một DC và chưa có DR độc lập.	Cập nhật DC Cầu Giấy và DR Nam Thăng Long; kiểm tra tài sản, hợp đồng, bản sao và diễn tập.	SRE / IDC
C4-SW-04	Nguồn ghi Đạt đối chiếu checksum bundle.	Tái kiểm tra đúng bundle đang dùng; checksum không tự chứng minh chữ ký hay nguồn phát hành.	DevSecOps

Không xóa nhận xét cũ khi đóng việc. Giữ báo cáo trước và sau, ticket thay đổi, EV retest và người chấp nhận. Nếu cùng một tồn tại ảnh hưởng nhiều kiểm soát, dùng chung mã việc/EV và liên kết đủ các dòng.

5 Trình tự bàn giao sang hồ sơ hành chính

Bước 1. Giao từng dòng trong workbook 04 cho một cá nhân. Các trường vàng là nơi nhập kết quả hiện tại, thời hạn, hành động và bằng chứng. Tab Nguon_v094 giữ dữ liệu lịch sử để đối chiếu.

Bước 2. Mỗi mã C4 được liên kết với mã TC/CL/HS/T liên quan trong workbook 02 khi người kiểm tra xác định đúng yêu cầu. Một mục C4 có thể liên quan nhiều dòng; không ghép tự động theo số thứ tự hoặc lấy căn cứ cũ làm căn cứ hiện hành.

Bước 3. Hoàn thành rà soát và phép thử phù hợp. Nếu đánh dấu Đạt hoặc Không áp dụng, phải có kết luận/hành động, EV, người xác minh và ngày. Trạng thái Đủ dữ liệu xác minh chỉ thể hiện đủ trường khai báo để người kiểm tra xem xét, không thay kết luận chuyên môn.

Bước 4. Chuyển dữ liệu được xác nhận sang phụ lục 10 của Bộ 2, thuyết minh, sổ rủi ro và báo cáo tự rà soát. Chủ quản chốt phạm vi, căn cứ cấp độ, phân công và thẩm quyền; kỹ thuật bàn giao bằng chứng có kiểm soát phiên bản.

Mốc nội bộ đề xuất	Đầu ra	Người xác nhận
Khởi động đối soát	Phạm vi hai site, danh sách dịch vụ, chủ việc 129 dòng và kho EV.	Khối Hạ tầng & Vận hành
Chốt thiết kế triển khai	BOM theo site, inventory, IP/port/rack map, luồng mạng và danh mục thay đổi.	Kiến trúc / Platform / NetOps / Storage
Xác nhận kết quả kỹ thuật	Kết quả T01–T12 áp dụng, retest, RPO/RTO đo được và rủi ro còn lại.	Người kiểm tra được phân công
Bàn giao hồ sơ	Workbook khóa phiên bản, phụ lục xác nhận, hồ sơ chuyên môn và danh sách còn thiếu.	Chủ trì lập hồ sơ / chuyên trách ANM

Thời hạn thực hiện và ngày hoàn thành do các đầu mối thống nhất, nhập vào workbook; chưa ấn định mốc cam kết khi chưa có kế hoạch nguồn lực được phê duyệt.